Handling data requests: procedure and register

A short procedure for an organisation that receives requests from people about their data: who receives them, the register, how to count the deadline, processors, refusals, and a check that nothing is missing.

FOR

Small and medium organisations in the EU, Iceland, Liechtenstein or Norway, and their data protection officer, that must answer requests under Articles 15 to 22 of the GDPR (the EU General Data Protection Regulation); notes for Italy and Germany.

NOT COVERED

Requests under other laws (freedom of information, medical records, personnel files) beyond a mention; public-sector and security restrictions beyond those named; national public holidays (the deadline moves to the next working day, but the holidays are not listed); the UK and Switzerland. The data protection laws of the states other than Bavaria were not read.

LAW AS OF

GDPR (Regulation (EU) 2016/679) as published on EUR-Lex, read 7 Nov 2026; EDPB Guidelines 01/2022 on the right of access, version 2.1 (adopted 28 March 2023, minor corrections 30 May 2024); Regulation (EEC, Euratom) 1182/71, Article 3; Italian Data Protection Code (Legislative Decree 196/2003) as on Normattiva (updated to the act published on 19 Feb 2026), read 4 to 8 Nov 2026; Garante complaint page (docweb 4535524), read 7 Nov 2026; BDSG as published on gesetze-im-internet.de, last amended by the Act of 12 May 2026, read 7 Nov 2026; Bavarian Data Protection Act (BayDSG) Articles 15 and 18, text in force from 1 Aug 2025 (gesetze-bayern.de), BDSG section 40(2) and the BfDI pages on the state authorities, read 8 Nov 2026

VERSION

1.1, 8 November 2026

What this procedure is for

People can ask an organisation for access to their data, or to correct, erase, restrict, transfer or stop using it, or to review an automated decision (Articles 15 to 22 GDPR). Every such request has the same deadline and the same rules on fees, identity and refusals (Article 12). The European Data Protection Board (EDPB), the body of all EU data protection regulators, says the precise deadline *"obliges the controller to be prepared for data subject inquiries by developing procedures for handling requests"* (EDPB Guidelines 01/2022, para. 6, p. 9). This is a short procedure to adapt. Fill in the parts in braces.

1. Who receives requests

Publish one contact for requests in the privacy notice: the controller's contact details and, where there is one, the data protection officer's (Article 13(1)(a) and (b); Article 37(7)). People *"may contact the data protection officer with regard to all issues related to processing of their personal data and to the exercise of their rights"* (Article 38(4)).

For access requests, the EDPB says no set form or legal reference is needed (para. 50, p. 22), and a request sent through a channel the organisation provides, other than the preferred one, *"shall be, in general, considered effective"* (para. 53, p. 23); the exception is a request sent to a random or wrong address the organisation did not provide, to the work address of staff not involved in handling requests (not the person's regular contact, such as an account manager, whose messages are not random: para. 55), or to a channel clearly not meant for such requests: the organisation need not act on it, but only if it has provided an appropriate channel the person can use (paras 54 to 55, p. 23). Staff who may receive requests (reception, customer service, account managers) forward them the same day to NAME OR TEAM.

REQUESTS ARE HANDLED BY (NAME, TEAM, E-MAIL) _____ DEPUTY WHEN ABSENT _____

2. Log every request

Keep one line per request. Write the deadline on the day the request arrives. Keep the register only as long as needed to show how requests were handled.

REFERENCE	DATE RECEIVED	RIGHT	IDENTITY CHECKED	DEADLINE	EXTENSION
Example: REQ-2026-014 (fictional)	Thu 5 Nov 2026, e-mail	Access (Art. 15)	Not needed: sent from registered e-mail	Mon 7 Dec 2026	No
REQ-...	DATE, CHANNEL	ART. 15 TO 22	HOW, OR NOT NEEDED	DATE	NO / NEW DATE AND REA

The GDPR sets no form for the register. A register helps the organisation meet its duty *"to be able to demonstrate that processing is performed in accordance with this Regulation"* (Article 24(1)), and to prove that a request was manifestly unfounded or excessive when it says so (Article 12(5)).

3. Check identity only when in doubt

Ask for more only with *"reasonable doubts concerning the identity"* and only for what is necessary (Article 12(6)). The EDPB says it is *"disproportionate to require a copy of an identity document"* from someone already authenticated (para. 73, p. 27). Use the identity reply in this set.

4. Count the deadline

The answer is due *"without undue delay and in any event within one month of receipt of the request"*; two more months are possible for complex or numerous requests, if the person is told within the first month with reasons (Article 12(3)). The EDPB counts under Regulation 1182/71. The period ends on the same date of the next month as the day the request arrived (the day of arrival itself is not counted); if that date does not exist, on the last day of that month; if the last day *"falls on a weekend or a public holiday, the controller has until the next working day to respond"* (EDPB, paras 160 to 161, pp. 50 to 51; Regulation 1182/71, Article 3(1), 3(2)(c) and 3(4)).

REQUEST ARRIVES	ONE MONTH ENDS	ANSWER DUE	IF EXTENDED (THREE MONTHS)
5 March (EDPB Example 32)	5 April	5 April, *"until and including"*	5 June
31 August (EDPB Example 33)	30 September (no 31 September)	Wednesday 30 September 2026	Monday 30 November 2026
Thursday 5 November 2026	Saturday 5 December 2026	Monday 7 December 2026, the next working day	Friday 5 February 2027; tell the person by Monday 7 December 2026

Fino's Response timeline counts the same way: it adds one calendar month (or three), uses the last day of the month where the date does not exist, and moves a Saturday or Sunday to the next working day. It does not know public holidays, so check whether the deadline day is one in your country.

For access requests the time may be suspended while the organisation waits for identity information or for the person to specify a very large request, provided it asked *"without undue delay"* (para. 159, p. 50).

5. Search, prepare and check the answer

Search all systems, paper files included, with criteria that match how the data is stored, such as name and customer number (EDPB, p. 4). Give the data as it stood when the request arrived; do not delete or correct it first (*"It has to give access first and delete the data afterwards"*, Example 6, p. 19). Where data is kept only briefly (for example

camera footage), keep what is needed to answer (para. 38, pp. 18 to 19).

Before sending a copy, remove what would *"adversely affect the rights and freedoms of others"* (Article 15(4)), but do not refuse the whole request on that ground (EDPB, p. 5). Send securely, for example encrypted (para. 40, p. 19). Use the answer reply in this set: it lists the Article 15 items.

6. Processors must help

A processor is a company that handles data on the organisation's behalf (IT provider, payroll, cloud). The processor agreement must require that the processor *"assists the controller by appropriate technical and organisational measures, insofar as this is possible, for the fulfilment of the controller's obligation to respond to requests for exercising the data subject's rights laid down in Chapter III"* (Article 28(3)(e)). Ask each processor that holds the person's data on the day the request is logged, and give it an internal deadline well before yours.

PROCESSORS HOLDING PERSONAL DATA, AND THEIR CONTACT FOR REQUESTS _____

7. Extensions, refusals and fees

An extension is *"an exemption from the general rule and should not be overused"* (para. 162, p. 51). A refusal must give the reasons and the right to complain and go to court, within one month (Article 12(4)). A fee or refusal for a manifestly unfounded or excessive request needs proof, and these concepts *"have to be interpreted narrowly"* (Article 12(5); para. 175, p. 55). Use the extension and refusal replies in this set.

8. Tell the recipients

After rectification, erasure or restriction, tell each recipient of the data, unless impossible or disproportionate, and tell the person who they are if asked (Article 19). This needs a record of who received what.

Key points of the EDPB Guidelines on the right of access

EDPB Guidelines 01/2022, version 2.1. Paragraph and page numbers refer to that PDF. The guidelines cover access only.

POINT	WHERE
Three parts: confirmation, access to the data, information about the processing	pp. 3 and 8, para. 3
No reason needed for a request, and no set form	p. 3; para. 50, p. 22
A request through any channel the organisation provides is in general effective	para. 53, p. 23
Confirming receipt with the one-month dates is good practice	para. 57, p. 24
Identity checks must be proportionate; an identity document copy is in general not appropriate	paras 65 to 79, pp. 25 to 29
The copy is of the data, not always of the documents (written before Case C-487/21: see the access letter in this set)	paras 23 and 152, pp. 13 and 48
Name the actual recipients; give precise storage periods	paras 117 to 118, p. 39
Answer as at the date of the request; give access before deleting	paras 37 to 39, pp. 18 to 19
Deadline counted under Regulation 1182/71; weekends and public holidays move it to the next working day	paras 160 to 161, pp. 50 to 51
Extensions are the exception; large effort alone is not complexity	paras 162 to 164, p. 51
Other people's rights: leave out or black out parts, do not refuse altogether	p. 5; paras 170 to 174, pp. 52 to 55
Manifestly unfounded or excessive: interpreted narrowly; tell the person before charging a fee	paras 175 to 194, pp. 55 to 59
National restrictions under Article 23 must be checked carefully and lifted when no longer justified	paras 196 to 198, p. 60

Is your procedure complete?

Tick each line. '?' means unknown: write who you asked.

LINE	WHAT IT SAYS	YES	NO	?
Art. 12(2) GDPR; EDPB 01/2022 para. 53	There is an easy way to make a request, and requests through any channel we provide are recognised and forwarded.	☐	☐	☐
Art. 37(7), 38(4) GDPR	The data protection officer's contact details, where there is one, are published and reach the person handling requests.	☐	☐	☐
Art. 12(3) GDPR; EDPB 01/2022 paras 160 to 161	Each request is logged on arrival with its deadline, counted as the EDPB counts it.	☐	☐	☐
Art. 12(3) GDPR	Extensions are used only for complexity or number, and the person is told within one month with reasons.	☐	☐	☐
Art. 12(6) GDPR; EDPB 01/2022 paras 65 to 79	Identity is checked only with reasonable doubts, with the lightest method that works, and identity copies are not kept.	☐	☐	☐
Art. 12(5) GDPR	Answers are free; a fee or refusal for a manifestly unfounded or excessive request is documented with proof.	☐	☐	☐
Art. 12(4) GDPR	Every refusal gives reasons and states the right to complain to a regulator and to go to court.	☐	☐	☐
Art. 15(1) to (3) GDPR	Access answers include the copy and every item of Article 15(1) and (2), tailored to the person.	☐	☐	☐
Art. 15(4) GDPR	Other people's data is removed from copies, without refusing the whole request.	☐	☐	☐
Art. 19 GDPR	We know who received each kind of data, so we can tell recipients about corrections, erasures and restrictions.	☐	☐	☐
Art. 21(3) GDPR	An objection to direct marketing stops marketing in every system and channel, including those run by providers.	☐	☐	☐

LINE	WHAT IT SAYS	YES	NO	?
Art. 28(3)(e) GDPR	Each processor agreement requires help with requests, and we know whom to contact at each processor.	☐	☐	☐
Art. 23 GDPR; EDPB 01/2022 para. 197	Any national restriction we rely on is identified by its provision, and its conditions are checked each time.	☐	☐	☐
EDPB 01/2022 para. 38 EDPB Guidelines 01/2022	Data with short retention (for example camera footage) can be kept when a request arrives, so it can still be given.	☐	☐	☐

The replies in this set: confirm receipt, confirm identity, extend the time limit, refuse or charge a fee, the answer.

The letters from the person: access, rectification, erasure, restriction, portability, objection, automated decisions.

Fined, and Article 12 among the breaches

Azienda Socio-sanitaria Territoriale Rhodense, Garante (Italy), 23 May 2024, €4,500: a correction request sent to the general certified e-mail address went unanswered for 156 days; the Garante held that address was not a 'random or incorrect' one; Articles 12 and 16 among the breaches (2024/IT/021). A large financial company (not named on the Fino page), Data Protection Authority of Hessen, annual report for 2024, fines totalling €496,000 in a settlement procedure: complaints showed late replies to access requests, among other findings; Articles 12(3) and 15 among the rules involved (2024/DE/003). Each fine covers all the breaches found, not this article alone. Amounts, dates and regulators as on Fino's decision pages.

Decision data come from enforcementtracker.com (provided by CMS) and GDPRhub (noyb), under CC BY-NC-SA 4.0 (https://creativecommons.org/licenses/by-nc-sa/4.0/), and from regulators' own publications; each decision page on Fino carries the details.

ITALY

Italy

Where a limit in Article 2-undecies of the Italian Data Protection Code applies, in the cases of letters (a), (b), (d), (e), (f) and (f-bis) of paragraph 1, the controller gives a reasoned notice without delay, unless the notice would defeat the purpose of the limit, and tells the person they may exercise their rights through the Garante (Code, Article 2-undecies(3)). For letter (c), parliamentary committees of inquiry, the rules of Parliament or the law setting up the committee apply instead (Code, Article 2-undecies(2)). Requests about a deceased person may come from someone with an interest of their own, an agent, or for family reasons worth protecting (Code, Article 2-terdecies); the procedure records how that link was checked.

Complaints go to the Garante per la protezione dei dati personali, which decides within nine months, or twelve with reasons (Code, Article 143(3); Garante, complaint model and instructions). Name it in refusals and answers.

GERMANY

Germany

Under the Federal Data Protection Act (*Bundesdatenschutzgesetz*, BDSG), for access the reasons for any refusal must be recorded and, as a rule, explained to the person (section 34(2) BDSG). Data stored to prepare and give an access answer may be used only for that purpose and for data protection control; for other purposes its processing is restricted (*"für andere Zwecke ist die Verarbeitung nach Maßgabe des Artikels 18 der Verordnung (EU) 2016/679 einzuschränken"*, section 34(2) BDSG). In Fino's reading this also covers register entries for access requests; no source confirms it.

The limits in sections 34 to 37 BDSG (access, erasure, objection against public bodies, insurance decisions) are summarised in the person letters in this set (sections 34 to 37 BDSG). The competent authority for a private company is in principle the data protection authority of the federal state where it is established or, if it has several establishments in Germany, of its main establishment (section 40(1) and (2) BDSG). According to the BfDI, the state authority supervises the state and municipal bodies of its state: *"Neben der Aufsicht über die Landes- und Kommunalbehörden wird auch der nicht-öffentliche Bereich grundsätzlich von den Landesdatenschutzbehörden betreut"* (besides supervising state and municipal authorities, the state data protection authorities in principle also cover the private sector) (BfDI: contact to the state authorities). Bavaria has two: the Bavarian State Office for Data Protection Supervision (*Landesamt für Datenschutzaufsicht*, in Ansbach) for companies and other private bodies, and the Bavarian State Commissioner for Data Protection (*Landesbeauftragter für den Datenschutz*) for Bavarian public bodies, municipalities included (Article 15(1) and Article 18(1) and (2) of the Bavarian Data Protection Act, BayDSG; BfDI page on Bavaria). The BfDI list of state authorities names them all.

For employees, the personnel-file right in section 83 of the Works Constitution Act runs alongside Article 15 (section 83 BetrVG); a request may invoke both, and the EDPB notes such requests may need separate replies (para. 47, p. 21).

Sources

GDPR, Regulation (EU) 2016/679 (EUR-Lex) • Used for: Articles 12, 15 to 22, 37, 38, 77 and 79, recitals; Fino's copy of each article is linked in the text

EDPB Guidelines 01/2022 on data subject rights: right of access, version 2.1 • Used for: How regulators read the right of access, time limits and identity checks (paragraphs and pages cited)

Regulation (EEC, Euratom) 1182/71 on periods, dates and time limits (EUR-Lex) • Used for: How a period in months is counted

Fino: Response timeline • Used for: Counting the one-month deadline

Italian Data Protection Code, Legislative Decree 196/2003 (Normattiva) • Used for: Articles 2-undecies, 2-terdecies, 140-bis to 143 and 152

Garante per la protezione dei dati personali: complaint model and instructions (docweb 4535524) • Used for: How to complain in Italy

Federal Data Protection Act, BDSG (gesetze-im-internet.de) • Used for: Sections 9, 19, 40 and 44 (regulators and courts) and the limits of the right in Germany

BfDI: list of the German state data protection authorities • Used for: Addresses of the regulators in Germany

Bavarian Data Protection Act (BayDSG), Articles 15 and 18 (gesetze-bayern.de) • Used for: The two Bavarian supervisory authorities: the State Commissioner for public bodies (Article 15(1)), the State Office in Ansbach for private bodies (Article 18(1) and (2))

BfDI: page on the Bavarian data protection authorities • Used for: Which Bavarian authority supervises whom, and the addresses

Works Constitution Act, section 83 (gesetze-im-internet.de) • Used for: Personnel file (Germany)